

Vulnerability Assessment Report

17st February 2026

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment will cover a period of three months, from June 2026 to August 2026. [NIST SP 800-30 Rev. 1](#) is used to guide the risk analysis of the information system.

Purpose

The primary purpose of this assessment is to identify and mitigate critical risks associated with the current public exposure of the e-commerce database. This server acts as the backbone of our operations, hosting sensitive **Personally Identifiable Information (PII)** and proprietary customer leads.

Ensuring the security of this data is vital for:

- **Business Continuity and Availability:** A server shutdown or a Denial of Service (DoS) attack would halt sales operations immediately, leading to direct financial losses and inability to process customer orders.
- **Data Integrity and Confidentiality:** Unauthorized access could lead to the silent modification of pricing, order records, or the exfiltration of sensitive customer data, resulting in a total loss of trust from our client base.
- **Legal Compliance and Reputation:** As an international e-commerce entity, maintaining an open database for three years poses a severe violation of data protection regulations (such as **LGPD or GDPR**). This exposure risks massive regulatory fines and irreparable damage to the company's market reputation.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
<i>Hacker</i>	<i>Conduct Denial of Service (DoS) attacks.</i>	3	3	9
<i>Advanced persistent threat (APT)</i>	<i>Install persistent and targeted network sniffers on organizational information systems.</i>	2	2	4
<i>Malicious software</i>	<i>Obtain sensitive information via exfiltration</i>	2	3	6

Approach

The threats chosen are related to the fact that the database is open for public, having TLS/SSL and updated linux do not exclude the fact that anyone with the port number of the server can try access (because is open) and stole PII data, shutdown the server or monitor the traffic, leading to a huge impact in the company reputation and the sales.

Remediation Strategy

Network Isolation via VPN and Firewall (Zero Trust Approach): The database must be removed from the public internet. We will implement a **Stateful Firewall** configured with a "Deny All" default policy, allowing incoming traffic on port 3306 **only** from the company's internal **Virtual Private Network (VPN)** gateway. Remote employees must authenticate via the VPN (preferably using **Multi-Factor Authentication - MFA**) before gaining network-level access to the database server.

System Hardening: Beyond OS updates, we will perform **Hardening** on the MySQL configuration. This includes disabling unused features, ensuring the service does not run with 'root' or 'sudo' privileges, and binding the MySQL service specifically to the internal network interface (localhost or private IP), preventing any accidental exposure to IPv4 public addresses.

Principle of Least Privilege (PoLP): We will conduct a full audit of database user accounts. Access will be restricted based on job functions (**Role-Based Access Control - RBAC**). For instance, marketing analysts will be granted SELECT (read-only) permissions to specific tables, while DROP, DELETE, or GRANT permissions will be strictly reserved for Senior DBAs.

Continuous Monitoring and Auditing: We will generate detailed logs of all connection attempts and queries executed. These logs must be exported to a centralized **SIEM (Security**

Information and Event Management) system to detect and alert on suspicious patterns, such as mass data exports or unauthorized access attempts in real-time.